Étude de cas — La directive NIS2

2026-11-05

Présentation

Les étudiants jouent la cellule cyber d'« Eaux du Val de Seine » (EVS), une entreprise fictive de distribution d'eau potable. Ils doivent qualifier l'entreprise au regard de NIS2, mesurer ses écarts, puis gérer un rançongiciel jusqu'aux notifications réglementaires.

Élément	Contenu
Public	Bac+4 / Bac+5 en informatique, cybersécurité ou management des SI
Durée	45 min de lecture préparatoire + 3 h 10 en séance
Format	Équipes de 4 à 5, rôles tournants (RSSI, DSI, juriste, direction générale, communication)
Prérequis	Notions d'analyse de risques, de gestion d'incident et de RGPD
Supports	Le texte de la directive, les annexes A1 à A5 de ce document, un ordinateur par équipe

Objectifs pédagogiques. À la fin de la séance, l'étudiant sait :

1. trouver et citer un article de la directive (UE) 2022/2555 et de sa transposition ;
2. qualifier une organisation : entité essentielle, importante ou hors champ ;
3. relier les 10 mesures de l'article 21 à des contrôles concrets et prioriser un plan d'action ;
4. appliquer le calendrier de notification de l'article 23 (24 h, 72 h, 1 mois) à un incident réel ;
5. expliquer la responsabilité des dirigeants et le régime de sanctions.

Livrables par équipe : une fiche de qualification, un tableau d'écarts avec plan à 90 jours, une alerte précoce rédigée, un calendrier de notification, et une restitution orale de 5 minutes.

Cadre temporel du cas. Au 5 novembre 2026, la France n'a pas encore transposé NIS2 (voir section suivante). Le cas se déroule donc en 2027, dans l'hypothèse où la loi est en vigueur. Les étudiants raisonnent sur le texte de la directive, qui fixe le socle commun à tous les États membres.

Où trouver la directive et les textes associés

Le texte officiel est sur EUR-Lex, sous la référence CELEX 32022L2555. En France, la loi de transposition n'est pas encore adoptée au 5 novembre 2026.

Texte	Référence	Où le lire
Directive (UE) 2022/2555 du 14 décembre 2022, dite NIS2	JO L 333 du 27.12.2022, p. 80–152 ; CELEX 32022L2555	EUR-Lex, version française (HTML et PDF dans toutes les langues de l'UE)
Règlement d'exécution (UE) 2024/2690	Exigences techniques pour les fournisseurs numériques (cloud, centres de données, MSP, MSSP, DNS…)	EUR-Lex, recherche « 2024/2690 »
Projet de loi relatif à la résilience des infrastructures critiques et au renforcement de la cybersécurité (« loi Résilience »)	Transpose NIS2 (titre II), la directive REC et un volet DORA	Dossiers législatifs du Sénat et de l'Assemblée nationale
Référentiel Cyber France (ReCyF) de l'ANSSI	Mesures de sécurité attendues, version de travail publiée le 17 mars 2026	messervices.cyber.gouv.fr/nis2
MonEspaceNIS2 (ANSSI)	Test d'éligibilité, pré-enregistrement ouvert le 24 novembre 2025	monespacenis2.cyber.gouv.fr

Dates clés de la directive. Adoptée le 14 décembre 2022, publiée le 27 décembre 2022, en vigueur depuis le 16 janvier 2023. Les États membres devaient la transposer avant le 17 octobre 2024 (article 41).

État de la transposition française au 5 novembre 2026 :

- 15 octobre 2024 : dépôt du projet de loi au Sénat, en procédure accélérée ;
- 12 mars 2025 : adoption en première lecture par le Sénat ;
- 10 septembre 2025 : adoption par la commission spéciale de l'Assemblée nationale ;
- 8 juillet 2026 : la Commission européenne saisit la Cour de justice de l'UE pour défaut de transposition ;
- 6 octobre 2026 : l'examen en séance prévu le 7 octobre est retiré de l'ordre du jour ;
- novembre 2026 : nouvelle inscription à partir du 9 novembre, sous réserve du calendrier budgétaire.

Après le vote de l'Assemblée, il faudra encore une éventuelle commission mixte paritaire, la promulgation, puis les décrets d'application. Tant que la loi n'est pas promulguée, ses obligations précises ne s'imposent pas aux entreprises françaises. L'ANSSI invite toutefois les entités à se préparer dès maintenant.

Conseil de lecture. Sur EUR-Lex, ouvrez la version française en HTML, utilisez le sommaire pour sauter aux articles, et gardez l'onglet ouvert pendant toute la séance. Les annexes I et II, en fin de texte, listent les secteurs.

Guide de lecture de la directive

La directive compte 144 considérants, 46 articles et 3 annexes. Pour ce cas, il suffit de lire en détail une dizaine d'articles et les annexes I et II.

Structure du texte

Chapitre	Articles	Contenu
I. Dispositions générales	1 à 6	Objet, champ d'application, entités essentielles et importantes, définitions
II. Cadres coordonnés en matière de cybersécurité	7 à 13	Stratégies nationales, autorités compétentes, CSIRT, divulgation des vulnérabilités
III. Coopération au niveau de l'Union et international	14 à 19	Groupe de coopération, réseau des CSIRT, EU-CyCLONe, examens par les pairs
IV. Gestion des risques et obligations d'information	20 à 25	Gouvernance, mesures de sécurité, notification des incidents, normalisation
V. Compétence et enregistrement	26 à 28	Territorialité, registre des entités, données d'enregistrement des noms de domaine
VI. Partage d'informations	29 et 30	Partage volontaire, notification volontaire
VII. Supervision et exécution	31 à 37	Contrôles, mesures d'exécution, amendes, assistance mutuelle
VIII. Actes délégués et d'exécution	38 et 39	Pouvoirs de la Commission
IX. Dispositions finales	40 à 46	Réexamen, transposition, abrogation de NIS1
Annexes I et II	—	Secteurs hautement critiques (I) et autres secteurs critiques (II)

Les articles à lire pour le cas

Article	Ce qu'il faut en retenir
Art. 2 — Champ d'application	La directive vise les entités des annexes I et II de taille moyenne ou plus : au moins 50 salariés, ou plus de 10 M€ de chiffre d'affaires et de bilan. Certaines entités sont visées quelle que soit leur taille (DNS, services de confiance qualifiés, administrations).
Art. 3 — Entités essentielles et importantes	Essentielle : entité de l'annexe I qui dépasse les plafonds d'une moyenne entreprise (250 salariés, ou plus de 50 M€ de CA et plus de 43 M€ de bilan), plus certains cas listés. Importante : toute autre entité des annexes I ou II dans le champ. L'État peut aussi désigner une entité comme essentielle.
Art. 20 — Gouvernance	Les organes de direction approuvent les mesures de l'article 21, supervisent leur mise en œuvre et peuvent en être tenus responsables. Leurs membres doivent suivre une formation.
Art. 21 — Mesures de gestion des risques	Approche « tous risques », mesures proportionnées. Le paragraphe 2 liste 10 mesures minimales, de a) à j).

Article	Ce qu'il faut en retenir
Art. 23 — Obligations d'information	Tout incident important est notifié au CSIRT ou à l'autorité : alerte précoce sous 24 h, notification sous 72 h, rapport final sous un mois.
Art. 32 et 33 — Supervision	Entités essentielles : contrôles a priori et a posteriori. Entités importantes : contrôles a posteriori, déclenchés par un indice de manquement.
Art. 34 — Amendes administratives	Plafond d'au moins 10 M€ ou 2 % du CA mondial pour une entité essentielle ; au moins 7 M€ ou 1,4 % pour une entité importante. Le montant le plus élevé s'applique.
Annexes I et II	18 secteurs au total : 11 hautement critiques (énergie, transports, banques, santé, eau potable, eaux usées, infrastructure numérique, gestion des services TIC, administration, espace…) et 7 autres (postes, déchets, chimie, alimentation, fabrication, fournisseurs numériques, recherche).

Les 10 mesures de l'article 21, paragraphe 2

- **a)** Politiques d'analyse des risques et de sécurité des systèmes d'information.
- **b)** Gestion des incidents.
- **c)** Continuité des activités : sauvegardes, reprise après sinistre, gestion de crise.
- **d)** Sécurité de la chaîne d'approvisionnement, y compris les relations avec les fournisseurs.
- **e)** Sécurité de l'acquisition, du développement et de la maintenance des systèmes, dont la gestion des vulnérabilités.
- **f)** Évaluation de l'efficacité des mesures.
- **g)** Cyberhygiène de base et formation.
- **h)** Cryptographie et chiffrement.
- **i)** Sécurité des ressources humaines, contrôle d'accès, gestion des actifs.
- **j)** Authentification multifacteur, communications sécurisées et systèmes de communication d'urgence.

Questions de lecture (à préparer avant la séance)

1. Quelle est la différence entre l'article 2 (qui est dans le champ ?) et l'article 3 (dans quelle catégorie ?) ?
2. Selon l'article 3, une entreprise de distribution d'eau de 210 salariés est-elle automatiquement essentielle ?
3. Qui, dans l'entreprise, engage sa responsabilité au titre de l'article 20 ?
4. Parmi les 10 mesures de l'article 21, lesquelles concernent directement un prestataire informatique ?
5. Quand un incident devient-il « important » au sens de l'article 23, paragraphe 3 ?

6. À partir de quel moment court le délai de 24 h ?
7. Quelle différence de supervision entre les articles 32 et 33 ?
8. Calculez le plafond d'amende d'une entité importante dont le CA est de 38 M€.

Le cas : Eaux du Val de Seine

EVS distribue l'eau potable de 120 000 habitants. Elle dépend d'un prestataire informatique peu sécurisé, et sa direction découvre NIS2 au moment où la loi française entre en vigueur. Toutes les organisations et personnes du cas sont fictives.

Contexte. Eaux du Val de Seine (EVS) est une SAS indépendante, délégataire du service public d'eau potable de la « Communauté d'agglomération du Val de Seine ». Aucun actionnaire n'en détient plus de 20 %. EVS exploite une usine de production, 14 réservoirs et 1 100 km de réseau, pour 48 000 abonnés.

Organisation	Rôle dans le cas	Effectif	CA annuel	Total du bilan
Eaux du Val de Seine (EVS)	Production et distribution d'eau potable	210 salariés	38 M€	41 M€
EVS Numérique	Filiale détenue à 100 % par EVS ; infogère la supervision (SCADA) de 12 petites communes voisines	35 salariés	6 M€	4 M€
TéléGest	Prestataire de services gérés (MSP) : administre à distance le SI et le SCADA d'EVS	80 salariés	12 M€	9 M€

Le système d'information d'EVS

- **SI de gestion :** facturation, relation client (48 000 dossiers avec RIB), SIG du réseau, messagerie en ligne.
- **SI industriel :** un SCADA pilote l'usine et les réservoirs ; les stations remontent leurs mesures par télérelevé.
- **Annuaire :** un seul Active Directory pour les deux mondes ; les réseaux bureautique et industriel communiquent librement.
- **Accès distant :** TéléGest se connecte par un VPN, avec un compte générique partagé par ses techniciens, sans authentification multifacteur.

La situation de départ. En janvier 2027, la directrice générale reçoit un courrier de l'ANSSI l'invitant à s'enregistrer sur MonEspaceNIS2. Elle demande à la cellule cyber, c'est-à-dire aux étudiants, trois choses :

1. EVS, sa filiale et son prestataire sont-ils concernés, et dans quelle catégorie ?
2. Où en sommes-nous par rapport aux exigences, et que faire d'abord ?

3. Sommes-nous prêts si une attaque survient demain ?

La troisième question devient réelle pendant la séance : un rançongiciel frappe EVS (phase 3).

Déroulé de la séance

La séance dure 3 h 10 en cinq phases, précédées d'une lecture individuelle. Chaque phase produit un livrable que l'enseignant valide avant la suivante.

Phase	Durée	Activité	Livrable	Articles mobilisés
0. Préparation	45 min (avant la séance)	Lecture guidée et questions de lecture	Réponses individuelles	2, 3, 20, 21, 23, 32 à 34
Lancement	10 min	Présentation du cas, formation des équipes, répartition des rôles	—	—
1. Qualification	30 min	Classer EVS, EVS Numérique et TéléGest	Fiche de qualification	2, 3, annexes I et II
2. Gouvernance et écarts	45 min	Confronter l'état des lieux (A2) aux 10 mesures	Tableau d'écarts + plan à 90 jours	20, 21
Pause	10 min	—	—	—
3. Gestion de crise	50 min	Rançongiciel, 5 injects successifs	Alerte précoce + calendrier de notification	23, RGPD art. 33 et 34
4. Supervision et sanctions	20 min	Contrôle de l'ANSSI après l'incident	Note à la direction générale	20, 32 à 34
5. Restitution et débriefing	25 min	5 min d'oral par équipe, puis synthèse	Présentation orale	—

Phase 0 — Préparation (avant la séance)

Chaque étudiant ouvre la directive sur EUR-Lex et répond aux 8 questions de lecture. Il note pour chaque réponse l'article et le paragraphe exacts. L'enseignant peut ramasser les réponses ou lancer la séance par un tour de table de 5 minutes.

Phase 1 — Qualification (30 min)

Consigne : « Pour EVS, EVS Numérique et TéléGest, dites si l'organisation est dans le champ de NIS2, dans quel secteur et dans quelle catégorie. Justifiez chaque réponse par un article. »

- Documents : fiche entreprise (A1), annexes I et II de la directive.

- Piège à repérer : la taille d'EVS Numérique ne s'apprécie pas seule, car c'est une filiale détenue à 100 %.
- Question bonus : l'État pourrait-il désigner EVS comme entité essentielle ? Sur quel fondement ?

Phase 2 — Gouvernance et écarts (45 min)

Consigne : « À partir de l'état des lieux (A2), évaluez EVS sur chacune des 10 mesures de l'article 21 (conforme, partiel, absent). Proposez ensuite les 5 actions à lancer dans les 90 jours, avec un responsable et un coût estimé (faible, moyen, élevé). »

- L'équipe joue le comité de direction : le « directeur général » doit approuver le plan (article 20).
- Exigence : au moins une action porte sur TéléGest (chaîne d'approvisionnement, mesure d).

Phase 3 — Gestion de crise (50 min)

L'enseignant distribue les injects de l'annexe A4 un par un, toutes les 8 à 10 minutes. Le temps du scénario avance plus vite que le temps réel.

Consigne : « Vous êtes la cellule de crise. À chaque inject, décidez des actions techniques, de communication et réglementaires. Avant la fin de la phase, remettez : (1) l'alerte précoce à l'ANSSI, rédigée avec le modèle A5 ; (2) le calendrier de toutes les notifications, avec leurs dates et heures limites. »

- Les équipes doivent aussi repérer l'obligation RGPD : des données d'abonnés ont fuité.
- L'enseignant peut jouer l'ANSSI, un journaliste local ou le président de l'agglomération.

Phase 4 — Supervision et sanctions (20 min)

Scénario : trois mois après l'incident, l'ANSSI annonce un contrôle. Elle a constaté que le compte VPN partagé de TéléGest n'avait toujours pas d'authentification multifacteur.

Consigne : « Rédigez une note d'une page à la directrice générale : type de contrôle applicable à EVS, mesures que l'autorité peut imposer, montant maximal de l'amende, responsabilité personnelle des dirigeants. »

Phase 5 — Restitution et débriefing (25 min)

Chaque équipe présente en 5 minutes sa qualification, ses 3 actions prioritaires et son calendrier de notification. La séance se conclut sur trois messages :

1. NIS2 engage la direction, pas seulement le RSSI ;
2. les délais de notification courent à partir de la prise de connaissance, pas de la fin de l'enquête ;
3. la sécurité d'une entité dépend de celle de ses prestataires.

Annexes

Cinq annexes sont distribuées au fil de la séance : A1 et A2 au début, A3 en phase 2, A4 inject par inject en phase 3, A5 avec le premier inject.

A1 — Fiche d'identité d'EVS

Rubrique	Données
Activité	Production et distribution d'eau destinée à la consommation humaine ; c'est l'activité principale
Clients	48 000 abonnés, soit 120 000 habitants dans 9 communes
Effectif	210 salariés, dont 6 à la DSI ; pas de RSSI dédié (le DSI cumule les deux rôles)
Finances (exercice 2026)	CA 38 M€ ; total du bilan 41 M€
Gouvernance	Une directrice générale, un comité de direction de 5 membres ; la cybersécurité n'y a jamais été abordée
Filiale	EVS Numérique, détenue à 100 % (35 salariés, CA 6 M€, bilan 4 M€)
Prestataire principal	TéléGest, infogérance du SI et du SCADA depuis 2019

A2 — État des lieux de la sécurité (audit interne, décembre 2026)

1. Aucune analyse de risques formalisée ; une politique de sécurité écrite en 2018, jamais mise à jour.
2. Pas de procédure de gestion des incidents ; l'astreinte d'exploitation appelle TéléGest en cas de problème.
3. Sauvegardes quotidiennes sur un NAS du même réseau, joint au domaine ; aucun test de restauration depuis 2024. Pas de plan de continuité ; l'usine peut fonctionner en mode manuel local.
4. Contrat TéléGest sans clause de sécurité (voir A3) ; compte VPN générique partagé.
5. Correctifs bureautiques appliqués chaque mois ; serveurs SCADA sous un système non maintenu depuis 2023.
6. Aucun audit ni test d'intrusion depuis cinq ans.
7. Pas de formation à la cybersécurité ; 31 % de clics lors d'un test d'hameçonnage en 2025.
8. Données des abonnés, RIB compris, non chiffrées dans la base de facturation.
9. Comptes des salariés partis non désactivés (42 comptes actifs de trop) ; pas d'inventaire à jour du matériel industriel.

10. Authentification multifacteur sur la messagerie uniquement ; pas de moyen de communication de secours en cas de panne du SI.

11. Un seul Active Directory et aucun cloisonnement entre réseaux bureautique et industriel.

A3 — Extrait du contrat avec TéléGest

> Article 4 — Accès. Le prestataire accède aux systèmes du client par un accès distant fourni par le client. Les identifiants sont communiqués au responsable technique du prestataire.
>
> Article 9 — Incidents. Le prestataire informe le client des dysfonctionnements constatés dans un délai raisonnable.
>
> Article 12 — Durée. Le contrat est conclu pour 5 ans, renouvelable tacitement. Aucune clause d'audit n'est prévue.

A4 — Chronologie de l'incident (injects)

N°	Date et heure du scénario	Inject
1	Lundi 15 mars 2027, 06 h 40	L'opérateur d'astreinte signale des écrans SCADA figés : 3 réservoirs ne sont plus pilotables à distance. Les postes bureautiques affichent une demande de rançon signée « LockSeine ». L'usine passe en mode manuel. À 07 h 00, le DSI confirme une attaque par rançongiciel.
2	Lundi 15 mars, 09 h 30	Le prestataire de réponse à incident établit que l'attaquant est entré le 12 mars à 23 h 15 par le compte VPN générique de TéléGest. La facturation, le CRM et le SIG sont chiffrés ; l'Active Directory est compromis ; les sauvegardes du NAS sont chiffrées aussi.
3	Lundi 15 mars, 14 h 00	Faute de télécommande, la pression chute dans 3 communes (8 000 habitants) pendant 6 heures. Le président de l'agglomération appelle la directrice générale ; un journaliste de la presse locale demande une interview.
4	Mardi 16 mars, 10 h 00	Les attaquants publient 2 000 fiches d'abonnés avec leur IBAN et affirment détenir les 48 000. Ils exigent 400 000 € sous 5 jours.
5	Jeudi 18 mars, 16 h 00	EVS Numérique découvre que le même compte TéléGest donnait accès aux SCADA de ses 12 communes clientes. L'une d'elles signale des connexions anormales.

A5 — Modèle d'alerte précoce

Champ	À compléter par l'équipe
Entité et numéro d'enregistrement	

Champ	À compléter par l'équipe
Catégorie (essentielle ou importante) et secteur	
Date et heure de prise de connaissance de l'incident	
Description sommaire et services touchés	
L'incident résulte-t-il d'un acte illicite ou malveillant ?	
Peut-il avoir un impact transfrontière ?	
Premières mesures prises	
Assistance demandée à l'ANSSI	
Contact de l'entité joignable 24 h/24	

Sources

Sources consultées le 5 novembre 2026. Les étudiants doivent toujours revenir au texte officiel sur EUR-Lex.

- Directive (UE) 2022/2555 (NIS2), EUR-Lex, version française
- Fiche NIS2 : référence au JO et règlement d'exécution 2024/2690 (Modulos)
- ANSSI, page NIS2 de MesServicesCyber (ReCyF, pré-enregistrement)
- ANSSI, présentation NIS2 du 27 mars 2026 (PDF)
- MonEspaceNIS2 (ANSSI)
- Donneespersonnelles.fr, enregistrement NIS2 et calendrier
- AOCSI, chronologie de la loi Résilience
- Forum des compétences, état de la procédure au 14 octobre 2026
- OpenKRITIS, NIS2 en France et saisine de la CJUE
- Next, report de l'examen du 7 octobre 2026
- Projet Arcadie, inscription possible à partir du 9 novembre (3 novembre 2026)
- Silicon, « NIS 2, le projet de loi de retour le 9 novembre » (5 novembre 2026)

À vérifier avant chaque séance : l'avancement de la loi Résilience et la publication des décrets, qui préciseront les modalités françaises de notification.